

MITRE ATT&CK 연구 흐름과 Git 프로젝트 도구 활용 설명

작성일: 2026 - 09 - 14 / 공개용 요약 / 원문 PDF/API 응답/비밀정보 미포함

먼저, 숫자 두 개를 구분해야 해

이번 작업에는 서로 다른 ‘ 5 ’ 와 ‘ 95 ’ 가 있어. 이 둘을 섞으면 선정 이유가 이상해져.

출발 논문 5편은 그래프를 시작하기 전에, ATT&CK 연구를 서로 다른 각도에서 보기 위해 고른 공개 PDF다. 루트 후보 95편은 그 5편의 참고문헌을 데이터베이스 관계로 최대 2단계 거슬러 올라가면서 나온 후보들이다. 따라서 95편 중 최종 5편을 확정한 상태는 아니다.

구분	무엇인가	현재 상태
출발 논문 5편	연구 지형/실증 평가/LLM 매핑을 함께 보기 위한 시작점	공개 PDF 보존 및 본문 텍스트 추출 완료
루트 후보 95편	출발 논문의 인용 경로에서 도달한 이전 연구/공식 자료 후보	원천성/인용 문맥은 아직 미확정

출발 논문 5편을 고른 이유

선정 기준은 제목 일치나 인용 수가 아니라, 같은 질문을 서로 다른 역할에서 검토할 수 있는가였다.

1. SoK: The MITRE ATT&CK Framework in Research and Practice

ATT&CK가 CTI/탐지/위험평가/레드/퍼플 팀에서 어떻게 쓰이는지 분류한 연구 지도다. 뒤의 후보를 ‘ CTI 추출/위험평가/위협모델링 ’ 가지로 나누는 기준이 된다.

2. How does Endpoint Detection use the MITRE ATT&CK Framework?

실제 EDR 규칙을 비교해 ‘ ATT&CK coverage가 높다 = 실제 방어가 좋다 ’ 라는 단순 해석을 경계하게 한다. 자동 매핑 결과를 평가할 때 필요한 현실 검증 축이다.

3. Rule - ATT&CK Mapper (RAM)

SIEM 규칙을 LLM과 외부 맥락으로 ATT&CK technique에 연결하는 방법이다. AI×보안의 자동화 방법을 대표하지만, 결과가 방어 성능을 뜻하는지는 2번의 관점으로 함께 봐야 한다.

4. MITRE ATT&CK Applications in Cybersecurity and The Way Forward

417편을 검토하고 backward/forward snowballing을 명시한다. ‘ 참고문헌을 계속 위로 타기 ’ 라는 이번 연구 방향과 가장 가까운 절차적 출발점이다.

5. MITRE ATT&CK: State of the Art and Way Forward

더 이른 시기의 분류체계를 제공한다. 1번/4번과 survey 성격은 겹치지만, 세 survey가 함께 참조하는 이전 연구를 찾는 비교 기준이 된다.

보완 관계

세 survey는 독립 실증 증거로 중복 계산하지 않는다. 대신 분야 지도 - > LLM 기반 자동 매핑 - > 실제 탐지/coverage 평가라는 역할 분담으로 함께 읽는다.

95개 루트 후보에서 우선 볼 5개

아래 5개는 ‘최종 선정’이 아니라, 5개 출발 논문 중 3개에서 도달했고 직접 인용된 출발 논문 수도 상대적으로 높은 우선 검토 대상이다. 원문 PDF 인용 문맥을 아직 확인하지 않았으므로 ‘연구의 최초 원천’이라고 부르면 안 된다.

MITRE ATT&CK - driven Cyber Risk Assessment

3/5 출발 논문에서 도달, 직접 인용 3편. ATT&CK 기반 위험평가라는 독립 가치를 대표한다.

Learning the Associations of MITRE ATT&CK Adversarial Techniques

3/5에서 도달, 직접 인용 2편. technique 사이 관계를 학습하는 방법 가치로, RAM의 자동 매핑과 비교할 수 있다.

Linking CVE 's to MITRE ATT&CK Techniques

3/5에서 도달, 직접 인용 2편. 취약점(CVE)을 공격기법(ATT&CK)으로 잇는 데이터/매핑 가치다.

Automated Retrieval of ATT&CK Tactics and Techniques for Cyber Threat Reports

3/5에서 도달, 직접 인용 2편. 위협 보고서에서 TTP를 추출하는 CTI/NLP 가치다.

Assessing MITRE ATT&CK Risk Using a Cyber - Security Culture Framework

3/5에서 도달, 직접 인용 2편. ATT&CK 위험평가를 조직/문화 관점으로 확장한 관련 가치다.

왜 다섯 개만 바로 확정하지 않았나

그래프는 인용 연결만 알려 준다. 논문이 중요한 이론적 기원인지, 단순 배경 인용인지, 실제로 어떤 문맥에서 인용됐는지는 PDF 참고문헌과 본문 인용 문맥을 확인해야 한다. Shannon 정보이론처럼 오래됐지만 ATT&CK와 직접 연결되지 않는 잡음도 2차 확장에서 발견됐다.

탐색 한계

1차는 출발 논문 5편에서 깊이 2, 최대 100노드로 실행되어 95개 후보가 나왔다. 2차는 상위 후보를 다시 시작점으로 했고 2개 조회 실패가 있었다. 따라서 ‘조회 실패가 적다’는 완전탐색의 증거가 아니며, 원천성은 미확정이다.

Git 프로젝트 속 도구: 무엇을 했고, 무엇을 할 수 있나

이 프로젝트는 한 모델이 모든 일을 하는 구조가 아니다. 각 도구가 맡는 단계가 다르다.

도구	역할	가능한 일	현재 상태
1. ai - trend 기반 수집 구조	공식 ACL Anthology/OpenReview 색인에서 후보를 모으는 구조의 출발점이다.	공식 게재 후보 수집, 실행별 원자료 스냅샷, 날짜/학회/논문 유형 기록.	ACL 2025 시험 수집에 실제 사용. 보안 학회 수집기는 아직 전 범위 구현이 아니다.
2. Scholar Search MCP	논문 메타데이터와 참고문헌 관계를 찾아 그래프를 만든다.	키워드 검색, 논문 ID 찾기, 참고문헌 역추적, 공통 루트 후보/경로 기록.	MITRE 출발 5편의 ID 확인, 1차/2차 그래프 확장에 실제 사용.
3. root - paper - lab MCP	위 도구들을 Hermes에서 안전한 연구 절차로 묶는 창구다.	검색, 공식 색인 수집, 공개 PDF 보존/SHA - 256, 루트 그래프, 검토 기록, 승인형 분석 호출.	이번 PDF 보존/실행기록/그래프 추적에 실제 사용. 논문 코드 실행 도구는 노출하지 않는다.
4. PaperQA	보존된 PDF에서 질문과 관련된 근거 문단을 찾고 분석 초안을 만드는 RAG 도구다.	PDF 근거 검색, 인용 위치를 포함한 질문 중심 분석 초안. 사람 검토를 대체하지 않는다.	설치/호환성 검사만 완료. 외부 LLM/임베딩 호출, PDF 외부 전송, 비용 발생 분석은 미실행.
5. Hermes 연구 검토	도구가 넓게 찾은 결과를 연구 질문에 맞춰 해석/기록한다.	공식 기록 대조, 잡음 제외/보류 근거, 후보/확정 분리, 보고서 작성.	2차 확장에서 일반 이론/주제 밖 항목을 원천으로 확정하지 않고 제외/대기열로 기록.

모델은 어디에 들어가나

모델은 참고문헌 그래프를 만드는 기본 도구가 아니다. PaperQA 분석 단계에서만 필요하다. 임베딩 모델은 ‘질문과 닮은 PDF 문단’을 찾고, LLM은 찾은 근거를 바탕으로 설명 초안을 쓴다. 이 단계는 원문 외부 전송과 비용이 생길 수 있으므로, 모델명/제공자/전송 범위/비용을 정한 뒤에만 실행한다.

현재 구현 상태: 후보 수집/공식 기록 확인/공개 PDF 보존/해시/참고문헌 그래프/실행 기록은 동작했다. 남은 핵심은 그래프를 여러 번 이어가는 frontier/cycle 보존 기능, 중요 후보의 원문 인용 문맥 확인, 그리고 승인 뒤 PaperQA 분석을 연결하는 일이다.

다음 다듬기 제안

내일은 기능을 더 많이 붙이기보다, 1) 95개 후보에서 가지별 우선 검토 큐를 남기고, 2) DB 인용 관계와 PDF 본문 인용 문맥을 구분하며, 3) 공식 MITRE 문서의 버전/판본을 확인하는 세 부분을 다듬으면 연구 흐름이 훨씬 단단해질 거야.